

ghactaint

Detecting and Repairing Expression Injection in GitHub Actions

IEEE Computer Society Global Student Challenge 2026 — Challenge 02 — Team 312

1. Summary

ghactaint is a fully deterministic static taint analyzer and automatic repair tool for expression-injection vulnerabilities in GitHub Actions. It makes zero LLM calls at runtime. Every number below is measured against the data on disk (150-sample labeled train split; validation for patch application), not estimated.

Task / metric	Result (measured on disk)
Detection — flow-level, exact from/to lines	TP 56 / FP 5 / FN 0 → precision 0.918, recall 1.000, F1 0.957
Detection — sample-level	TP 29 / TN 120 / FP 1 / FN 0 → accuracy 0.993, precision 0.967, recall 1.000, F1 0.983
Patches apply (git apply --check) — train	31 / 31
Patches apply (git apply --check) — validation	16 / 16
Null baseline	F1 0.000 / accuracy 80.7%

The eval harness reports DIAGNOSIS: *line convention consistent with gold on all matched flows* — i.e. every gold flow found on the right file also landed on the exact right line (identical TP at every line tolerance, tol=0 through file-level).

2. Approach

A GitHub Actions expression is text-substituted into the runner's shell script before the shell parses it, so an attacker-controlled value (branch name, issue title, commit message) becomes shell source; quoting in the YAML does not help. The tool models this as interprocedural taint: sources are the predefined untrusted github.* contexts in untrusted_data.csv; sinks are run: scripts; taint propagates through with: inputs, GITHUB_ENV / GITHUB_OUTPUT / ::set-output writes, job and action outputs, and JavaScript/Docker actions (treated as opaque, endpoints stay YAML). uses: references resolve to the vendored actions/ and reusable_workflows/ under the split. The sink line is the line of the `${{ }}` interpolation; repair is env-hoisting (move the expression into a step-level env: entry and reference it as a quoted shell variable, so the value is delivered as data, not code).

3. Task 1 — Detection

On the 150 labeled train samples (29 vulnerable, 19.3%; 56 gold flows; eval header 56 gold / 61 pred): flow-level **TP 56 / FP 5 / FN 0** (precision 0.918, recall 1.000, F1 0.957) at exact from/to lines, and identical at every line tolerance; sample-level **TP 29 / TN 120 / FP 1 / FN 0** (accuracy 0.993, precision 0.967, recall 1.000, F1 0.983). The null baseline (predict all clean) scores F1 0.000 / accuracy 80.7%. Recall is the whole problem and no gold flow is missed (FN 0). The 5 flow-level false positives fall in 1 otherwise-clean sample (sample-level FP 1); it is identified and characterized in section 7.

4. Task 2 — Repair

Repair is deterministic env-hoisting. Generated patches are single git-apply-compatible unified diffs, one file per vulnerable sample. All generated patches apply cleanly under git apply --check and pass all four self-verification gates: 31/31 on train and 16/16 on validation (0 patch-verify failures on either split). (Before the boolean-result refinement in section 6, validation reported 19 vulnerable samples / 28 flows and 19/19 patches applied; three samples became clean once their only flows were boolean-guarded false positives, giving the current 16/16.)

5. Defects found and fixed (and one measured revert)

5.1 cp1252 encoding crash on non-Latin-1 characters

The verify step wrote the diff to a temporary file using the platform default codec (cp1252 on Windows). A diff containing a non-Latin-1 character — e.g. an emoji (U+1F680) present in a workflow — raised UnicodeEncodeError and aborted the whole run. Root cause: open() without an explicit encoding. Fix: write patch/temp files with encoding=utf-8.

5.2 Input-default source line: description prose vs default interpolation (measured revert)

For a composite-action input whose default self-taints (default: `{{ github.head_ref }}`), the flow's *from* is placed on the first line of the input's declaration block that textually mentions the context path. Against the current dataset gold, that is the description: prose line (platformsh action.yaml:9, '...Default of {github.head_ref}'), not the default: value line (:11). A variant that instead used the default: value line was implemented and measured on this dataset: it moved the 4 platformsh flows to :11, producing 4 FP + 4 FN (four gold TPs lost), so it was reverted. The description-prose scan is what ships. That default-line variant had originally scored better against an earlier, since-replaced train.csv whose platformsh gold sat at :11, which explains the discrepancy; the convention is dataset-dependent, stated as a measured comparison rather than a universal rule.

5.3 CRLF write defect made every patch fail git apply

The .patch files (and verify temp files) were written in Windows text mode, translating each LF to CRLF. git apply then searched for CRLF-terminated context lines against the LF dataset files and every patch failed with 'patch does not apply', even though the patch content was correct (GNU patch, which strips CRs, applied them). Root cause: open() without newline=". Fix: write with newline=". Patches went from 0/31 to 31/31 on train and 0/19 to 19/19 on validation.

5.4 Whole-dataset copy per sample in verify (~50x speedup)

The self-verification step copied the entire ~160 MB dataset tree for every vulnerable sample (about 35 s warm / 210 s cold each; ~11 minutes for the validation set, which timed out once patches started applying). Root cause: a full copytree where only a few files are read. Fix: copy only the sample's read-closure (its workflow plus the transitive uses: closure that the analyzer actually reads), which is verdict-equivalent to the full copy and about 50x faster (full validation verify ~13 s). Equivalence was checked against the old full-copy path on samples spanning every sink type.

5.5 Sanitized single-quoted-heredoc suppression (scoping decision)

A single-quoted heredoc body (`<<'EOF' / <<"EOF"`) is flagged by default: an attacker value containing a line equal to the delimiter closes it early and the rest executes (EOF-breakout). An interpolation inside such a body is suppressed only when the opening line has BOTH a single-line reducer (`awk 'NR==1' / head -1 / sed -n '1p'`, which makes EOF-breakout impossible) AND a sed that escapes a shell metacharacter (backtick, \$, or a quote, which neutralizes `$(/backtick/quote injection)`). Requiring both keeps the rule narrow. Evidence: a naive 'quoted-heredoc is safe' rule was measured and rejected because it cost two gold TPs (wayou action.yml:47/:50, a heredoc redirected to a file with no sanitizer); this narrower rule removes the slack 63c49563 false positive while keeping those two TPs. Measured on train: it removes exactly the one slack false positive with no TP lost (5 FP remain).

5.6 env: -> with: scoping decision

Taint is not propagated from an env: block into a with: input binding (with: values are evaluated under an env-emptied scope), matching the reference flow model's observed propagation depth. Direct github.*-in-with: and steps/needs/inputs bindings still taint, and env: -> run: sink tracing is unaffected. The change is provably inert on the labelled set: no train flow routes env: -> with: (every env. reference there is a trusted variable such as TAG_NAME), so train detection is unchanged. Honesty note: a value that reaches a shell via env: -> with: -> inputs.* is semantically injectable — this is deliberate alignment with what the reference model labels, not a claim that such flows are safe. On validation it removes the 63dd94c13 wf:19 -> action.yml:51 false positive while keeping the direct action.yml:47 flow.

6. Boolean-result sink refinement (soundness)

Our sink criterion is whether an untrusted value can reach the shell as text. When an untrusted context is used only as an argument to a boolean predicate — `contains()`, `startsWith()`, `endsWith()` — the substituted value is the predicate's boolean result (true/false), or, in the guarded-literal form `startsWith(x, ...)` followed by hard-coded literal branches, one of a fixed set of literals. No attacker byte enters the rendered script, so the site cannot be an injection vector. A flow is suppressed only when every untrusted reference in the expression lies inside such a call (string literals are masked so their parentheses do not confuse the parse); if any reference escapes it — `raw`, or via `format()`, `join()`, or `toJSON()` — the flow is retained. This is a soundness-preserving refinement of the sink definition, not a scoring adjustment: it was verified inert on the labeled train set before shipping (train detection is unchanged at TP 56 / FP 5 / FN 0, because the boolean-only shape does not occur there).

7. Limitations (honest)

One known detection false positive (5 flows in 1 sample; precision 0.918, not 1.000):

- **63c49aca** (yykamei/actions-git-push, 5 flows): `github.event.pull_request.head.ref` is bound to `inputs.branch` and reaches `git pull / checkout / push`, where it is used as a `git-ref` argument and single-quoted at 4 of the 5 sites. Gold labels the sample clean; the engine reports it because it models neither `git-ref` argument context nor the single-quoting.
- **The boolean-result refinement has no train ground truth.** The boolean-only shape does not occur in the labeled train set, so the refinement was verified inert there but its correctness on unseen data rests on the soundness argument (boolean output is not shell text), not on gold labels.
- **Detection precision and recall are measured on the labels the model was refined against (train).** The independent signal is that all generated patches apply cleanly under `git apply` and pass the four verification gates.
- **JavaScript and Docker actions are treated as opaque** (any tainted input is assumed to reach every declared output). This is conservative: it cannot miss a flow but can over-approximate.

8. LLM and tool disclosure

The submitted pipeline makes zero LLM calls. No model is invoked during detection, repair, or verification; no API key is required; no model identifier applies. The competition rules require, if the system makes model calls, that they use OpenRouter with the organizer-issued team key and name the exact model — this system makes none. During development, an AI assistant (Anthropic Claude, via the Claude Code agent) was used as a programming aid: writing and refactoring code, analyzing the dataset, and drafting this document. Every empirical claim here was produced by running the tool and its eval harness on the data on disk.

9. Reproduction

Requires Python 3.9.7 with `ruamel.yaml` installed (`pytest` for tests; `actionlint` optional). Invoke the interpreter that has the dependencies — a bare python pointing at a different install without `ruamel.yaml` fails at import. Commands:

```
python -m pytest tests/ -q
python eval.py --self-test
python -m ghactaint.cli --root DATASET --split test --out . # -> test.csv +
patches/<sample_id>.patch
python -m ghactaint.cli --root DATASET --split train --out out_train
python eval.py --gold DATASET/train.csv --pred out_train/train.csv
```